대외비 2급

개인정보보호 관리지침서

2012. 02

연세대학교 의료원
YONSEI UNIVERSITY HEALTH SYSTEM

제 개정 이력

제 개정번호	일자	제 개정 내용 요약	작성자
2012-01	2012-02-22	ISO27001 인증 대비 전면 개정	조남인
2016-01	2016-01-29	제42조 (개인정보의 안전성 확보조치에 관한 사항) 제1항의 4 신설 제43조 (개인정보보호 교육) 제1항, 제2항, 제3항 문구 수정	조남인
2016-02	2016-09-26	위원회 명칭 변경 (정보보호 위원회)	조남인
2016-03	2017-01-16	내부관리계획 필수구성 요소 추가	조남인
2019-01	2019-10-22	제45조 (개인정보의 안전성 확보조치에 관한 사항) 행안부 안전성 확보조치 기준 문구 추가	조남인
2020-01	2020-11-04	제42조 개인정보 유출 신고 기준 수정	조남인
2023-01	2024-01-08	제30조(환자건강정보의 접근 권한관리) 제54조(이용, 제3자제공, 파기의 기록 및 관리) 제59조(기타 개인정보보호 정책)	조남인
2024-01	2024-12-23	제15조(개인정보 수집 출처 등 고지)	조남인

목 차

제 1 장 총칙 4
제 1 조 (목적) 4
제 2 조 (적용범위) 4
제 3 조 (용어의 정의) 4
제 2 장 개인정보보호 처리 기준 6
제 4 조 (개인정보 보호 원칙) 6
제 5 조 (개인정보 보호책임자의 지정) 6
제 6 조 (개인정보 보호책임자의 의무와 책임) 6
제 7 조 (개인정보취급자의 범위 및 의무와 책임) 7
제 8 조 (처리하는 개인정보의 항목) 7
제 9 조 (개인정보의 처리 목적) 8
제 10 조 (개인정보의 제 3 자 제공에 관한 사항) 8
제 11 조 (환자건강정보 및 회원정보 수집, 제공 경로) 9
제 12 조 (환자건강정보 및 회원정보의 수집, 이용 및 제공) 9
제 13 조 (수집, 이용 및 제공 등에 관한 동의 및 고지) 10
제 14 조 (개인정보의 목적 외 이용 등) 12
제 15 조 (개인정보 수집 출처 등 고지) 13
제 16 조 삭제 <2017.01.16> 13
제 17 조 (개인정보처리방침의 작성) 13
제 18 조 (개인정보처리방침의 작성기준 등) 13
제 19 조 (개인정보처리방침의 변경에 관한 사항) 14
제 20 조 삭제 <2017.01.16> 14
제 21 조 (환자건강정보 수집 및 이용의 동의 철회) 14
제 22 조 (환자건강정보 수집 및 이용의 정정 요청 절차) 15
제 23 조 (환자건강정보의 열람 및 사본발급 절차) 15

제 24 조 (환자건강정보의 생성과 갱신, 소멸) 15
제 25 조 (환자건강정보의 유지 및 관리) 16
제 26 조 (필수 항목) 16
제 27 조 (정보주체 및 법정대리인의 권리 · 의무 및 그 행사방법에 관한 사항) 16
제 28 조 (동의철회 및 개인정보 파기에 관한 사항) 17
제 29 조 (서비스 개발) 17
제 30 조 (환자건강정보의 접근 권한관리) 18
제 31 조 (비밀번호 관리) 18
제 32 조 (환자건강정보의 접근 로그 관리) 18
제 33 조 (환자건강정보의 출력 조치) 19
제 34 조 (개인정보처리의 위탁에 관한 사항) 19
제 35 조 (개인정보 처리 위탁관리의 보호 조치) 19
제 36 조 (외부 연구자의 보호 조치) 19
제 37 조 (자원봉사자와 호스피스의 보호 조치) 20
제 38 조 (서약서 관리) 20
제 39 조 (환자건강정보 비밀 누설금지) 20
제 40 조 (개인정보 유출 통지시기 및 항목) 20
제 41 조 (개인정보 유출 통지방법) 21
제 42 조 (개인정보 유출 신고) 21
제 43 조 (개인정보의 처리 및 보유기간에 관한 사항) 21
제 44 조 (개인정보의 파기방법 및 절차) 22
제 45 조 (개인정보의 안전성 확보조치에 관한 사항) 23
제 46 조 (개인정보 보호 교육) 25
제 47 조 (개인정보의 식별) 25
제 48 조 삭제 <2017.01.16> 25
제 49 조 삭제 <2017.01.16> 25
제 50 조 (위험도 분석 및 대응방안 마련) 26

제 3 장 영상정보처리기기 처리 기준 26
제 51 조 (영상정보처리기기 설치 운영) 26
제 52 조 (개인영상정보 이용. 제 3 자 제공 등 제한 등) 26
제 53 조 (보관 및 파기) 27
제 54 조 (이용. 제 3 자 제공. 파기의 기록 및 관리) 27
제 55 조 (영상정보처리기기 설치 및 관리 등의 위탁) 27
제 56 조 (정보주체의 열람 등 요구) 28
제 57 조 (정보주체의 권익침해에 대한 구제방법) 28
제 58 조 (개인영상정보의 안전성 확보를 위한 조치) 29
제 59 조 (기타 개인정보보호 정책) 29
제 60 조 (시행과 갱신) 30

제1장 총칙

제1조(목적)

본 지침서는 연세대학교 의료원(이하 산하기관을 포함하여 '의료원'이라 칭함)의 개인정보를 수집·처리함에 있어 환자 및 교직원, 학생의 권리를 보호하고 개인정보의 체계적인 보안 관리 및 기타 필요 사항을 규정하여 정보자산의 훼손, 변조, 도난, 유출 등의 위협으로부터 효과적으로 대비하고 예방하는 것을 목적으로 한다.

제2조(적용범위)

본 지침서의 적용범위는 의료원 정보시스템에 저장되고, 관리되는 환자건강정보 및 학생, 내·외부 직원의 개인정보를 대상으로 전자적 처리 여부를 불문하고 수기문서를 포함한 모든 형태의 개인정보파일을 운용하는 모든 교직원과 의료원과 관련된 업무를 수행하는 외부용역업체에게 적용된다.

제3조(용어의 정의)

① "환자건강정보" 라 함은 진료목적으로 얻은 환자 개인의 신체상황, 상병, 치료, 과거병력, 가족병력 등의 진료기록과 이와 함께 포함되어 있는 환자의 성명, 성별, 주소, 주민등록번호 또는 유전자 정보 등 개인 식별이 가능한 정보(당해 정보만으로는 특정 개인을 식별할 수 없더라도 다른 정보와 용이하게 결합하여 식별할 수 있는 것을 포함)를 말한다.

② "개인식별정보" 라 함은 개인을 직접 식별하거나 유추하여 알 수 있는 모든 정보, 성명, 주소, 이메일주소, 주민등록번호 등 개인 정보를 말한다.

③ "개인정보파일"이라 함은 개인정보처리스템에 보관 관리되고 있는 개인정보와 환자건강정보를포함한 파일 및 출력물을 총칭하여 말한다.

④ "정보주체" 라 함은 취급되는 정보에 의하여 식별되는 자로서 당해 정보의 주체가 되는 자를 말한다. 다만, 정보주체가 의사 무능력 상태이거나 미성년자의 경우 건강주체가 위임한 대리인 또는 법정대리인을 정보주체로 간주한다.

⑤ "개인정보처리자"라 함은 개인정보를 처리하는 모든 공공기관, 영리목적의 사업자, 협회·동창회 등 비영리기관·단체, 개인 등을 말한다.

⑥ "개인정보취급자"라 함은 개인정보처리자의 지휘·감독을 받아 개인정보를 처리하는

업무를 담당하는 자로서 직접 개인정보에 관한 업무를 담당하는 자와 그 밖에 업무상 필요에 의해 개인정보에 접근하여 처리하는 모든 자를 말한다.

⑦ “개인정보처리시스템” 이라 함은 개인정보를 처리할 수 있도록 체계적으로 구성한 데이터베이스시스템을 말한다.

⑧ “대리인” 이라 함은 위임을 받지 않고도 직접 법률규정에 의하여 대리권의 효력이 발생하는 법정대리인과 정보주체가 지정한 대리인을 말한다.

⑨ “제3자”라 함은 정보주체와 정보주체 또는 그의 법정대리인으로부터 개인정보를 실질적/직접적으로 수집 및 보유한 개인정보처리자를 제외한 모든 자를 말한다.

⑩ “동의” 라 함은 정보주체로 하여금 환자건강정보의 처리에 대하여 인식하거나 수락할 때 의사표시를 말한다.

⑪ “처리” 라 함은 환자건강정보의 수집, 생성, 기록, 저장, 가공, 편집, 검색, 출력, 전송, 정정, 복구, 이용, 제공, 공개, 파기 및 기타 이와 유사한 일체의 행위 또는 활동을 말한다.

⑫ “제공”이라 함은 개인정보의 저장매체 또는 개인정보가 담긴 출력물이나 책자 등의 물리적 이전, 네트워크를 통한 개인정보의 전송, 개인정보에 대한 제3자의 접근권한 부여, 개인정보처리자와 제3자의 개인정보 공유 등 개인정보의 이전과 공동으로 이용할 수 있는 상태를 초래하는 모든 행위를 말한다.

⑬ “전자문서” 라 함은 컴퓨터 등 정보처리능력을 가진 장치에 의하여 전자적인 형태로 작성되어 송・수신 또는 저장된 문서형식의 자료를 말한다.

⑭ “전자서명” 이라 함은 전자서명법에 의한 공인인증기관이 발급한 공인전자인증서에 기초한 전자서명을 말한다.

⑮ “공인인증서”라 함은 전자서명법 제15조(인증서 발급 등) 규정에 따라 공인인증기관이 발급하는 인증서를 말한다.

16 “침해사고” 라 함은 해킹, 컴퓨터바이러스, 논리폭탄, 메일폭탄, 서비스 거부, 고출력 전자기파 등에 의해 정보통신망과 정보시스템을 공격하는 행위로 인하여 발생한 사태를 말한다.

17 “회원정보”라 함은 특정 서비스 이용을 위해 가입 절차가 필요한 경우 본인의 의사에 따라 제공된 정보로 환자 여부와 관계없이 회원 가입을 할 수 있다.

제2장 개인정보보호 처리 기준

제4조(개인정보 보호 원칙)

개인정보를 수집하는 목적은 수집 당시에 명확히 특정되어 있어야 하고 개인정보처리자는 그 특정된 목적을 달성하기 위하여 직접적으로 필요한 범위 내에서만 개인정보를 처리하여야 한다.

개인정보처리자는 개인정보의 내용이 처리 당시의 사실에 부합하도록 정확하고 최신의 상태를 유지하여야 하며, 개인정보의 처리과정에서 고의 또는 과실로 개인정보가 부당하게 변경 또는 훼손되지 않도록 하여야 한다.

개인정보처리자는 정보주체의 권리가 침해 받을 가능성과 위험의 정도에 상응하는 적절한 기술적·관리적 및 물리적 보안조치를 통하여 개인정보를 안전하게 관리하여야 한다.

개인정보처리자는 개인정보 처리방침 등 개인정보의 처리에 관한 사항을 일반적으로 공개하여야 하며, 열람청구권 등 정보주체의 권리가 보장될 수 있도록 합리적인 절차를 마련하여야 한다.

개인정보처리자는 처리 목적에 필요한 범위에서 개인정보를 처리하는 경우에도 가능한 한 정보주체의 사생활 침해를 최소화하는 방법을 선택하여야 한다.

개인정보처리자는 이 법에 의하여 개인정보의 처리에 관한 정보주체의 동의를 얻은 경우라도 구체적인 업무의 특성상 가능한 경우에는 특정 개인을 알아볼 수 없는 형태로 개인정보를 처리하여야 한다.

제5조(개인정보 보호책임자의 지정)

의료원은 개인정보보호법 시행령 제32조제2항1호에 따라 디지털헬스실장을 개인정보 보호책임자로 지정한다.

제6조(개인정보 보호책임자의 의무와 책임)

개인정보 보호책임자는 정보주체의 개인정보 보호를 위하여 다음 각 호의 업무를 수행한다.

1. 개인정보 보호 계획의 수립 및 시행
2. 개인정보 처리 실태 및 관행의 정기적인 조사 및 개선
3. 개인정보 처리와 관련한 불만의 처리 및 피해 구제

4. 개인정보 유출 및 오용·남용 방지를 위한 내부통제시스템의 구축
5. 개인정보 보호 교육 계획의 수립 및 시행
6. 개인정보파일의 보호 및 관리·감독
7. 그 밖에 개인정보의 적절한 처리를 위하여 대통령령으로 정한 업무

① 개인정보 보호책임자는 업무를 수행함에 있어서 필요한 경우 개인정보 처리 현황, 처리 체계 등에 대하여 수시로 조사하거나 관계 당사자로부터 보고를 받을 수 있다.

② 개인정보 보호책임자는 개인정보 보호와 관련하여 개인정보 보호법 및 다른 관계 법령의 위반 사실을 알게 된 경우에는 즉시 개선조치 하여야 한다.

제7조(개인정보취급자의 범위 및 의무와 책임)

① 개인정보취급자의 범위는 다음과 같다

0. 의료원 내에서 정보주체의 개인정보를 처리하는 업무를 수행하는 자를 말하며, 정규직 외에 임시직, 파견근로자, 시간제근로자, 개인정보 수탁업체 등이 포함된다.

② 개인정보취급자의 의무와 책임

0. 개인정보보호 관리 지침서의 준수 및 이행
1. 개인정보의 기술적·관리적 보호조치 기준의 이행
2. 업무상 알게 된 개인정보를 제3자에게 제공 금지
3. 소속직원 또는 제3자에 의한 위법·부당한 개인정보 침해행위에 대한 신고
4. 기타 개인정보보호를 위해 필요한 사항의 이행

제8조(처리하는 개인정보의 항목)

① 진료정보 수집 항목 : 성명, 주민등록번호(또는 외국인등록번호), 주소, 전화번호, 진찰권번호, 만14세 미만 아동 및 건강상의 이유로 의사표시를 할 수 없는 자의 경우 법정대리인의 정보(성명, 연락처, 관계), 진료서비스를 위하여 의료진이 필요하다고 판단하는 병력 및 가족력 등의 건강정보

② 의료법에 의해 고유식별정보 및 진료정보를 의무적으로 보유하여야 함(별도 동의 불필요)

③ 추가 서비스 정보 수집 항목 : 성명, 주소, 전화번호, 이메일, 만14세 미만 아동 및 건강상의 이유로 의사표시를 할 수 없는 자의 경우 법정대리인의 정보(성명, 전화번호,

환자와의 관계)

제9조(개인정보의 처리 목적)

① 본인 식별, 진단과 치료를 위한 진료기록부 기재 및 진료서비스 제공

② 진료비 및 보험심사 청구, 수납, 환급, 예약, 제증명서 발급 등의 원무서비스 제공

③ 외부 위탁검사에 필요한 정보 제공

④ 진료의뢰 및 회송 받은 타 의료기관에 진료정보 제공

⑤ 교육, 연구, 치료결과 추후조사에 필요한 자료

⑥ 고지사항 전달, 불만처리 등을 위한 의사소통 경로로 이용

⑦ 건강컨텐츠, 새로운 서비스 및 행사정보 안내 제공

제10조 (개인정보의 제3자 제공에 관한 사항)

① 의료원은 개인정보를 제6조(개인정보의 처리 목적)에서 고지한 범위 내에서 사용하며, 동 범위를 넘어서 이용하거나 타인 또는 타기업, 기관에 제공하지 아니한다. 다만, 정보주체의 동의가 있거나 다음과 같은 사례에 해당하는 경우에는 예외로 한다.

0. 통계작성, 학술연구 또는 시장조사를 위하여 필요한 경우로서 특정 개인을 알아볼 수 없는 형태로 가공하여 연구단체, 설문조사, 리서치기관 등 제 3자에게 제공하는 경우
1. 개인정보보호법, 금융실명거래 및 비밀보장에 관한 법률, 신용정보의 이용 및 보호에 관한 법률, 의료법, 의료급여법, 국민건강보험법, 통계법, 소비자보호법, 형사소송법, 민사소송법 등 법률에 특별한 규정이 있는 경우
2. 법률에 특별한 규정이 있거나 법령상 의무를 준수하기 위하여 불가피한 경우('법률에 특별한 규정이 있는 경우'로 행정목적이나 수사목적으로 행정관청이나 수사기관이 요구할 경우라도 법률에 규정된 바에 따라 영장 또는 수사 기관장의 직인이 날인된 서면에 의한 경우 등 적법한 절차에 따라 제공한다).
3. 정보주체 또는 그 법정대리인이 의사표시를 할 수 없는 상태에 있거나 주소불명 등으로 사전 동의를 받을 수 없는 경우로서 명백히 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익을 위하여 필요하다고 인정되는 경우

4. 개인정보를 동의 받은 목적 외의 용도로 제공할 경우 사전에 개별적으로 전자우편 및 서면을 통해 고지하여 동의를 구하는 절차를 거치게 되며, 정보주체가 동의하지 않는 경우에는 제공단체 및 기관에 제공하지 않는다.
5. 정보주체는 개인정보의 제3자 제공에 대하여 동의를 하지 않거나 언제든지 철회할 수 있으나, 이 경우 관련 서비스의 이용이 제한될 수 있다.

제11조 (환자건강정보 및 회원정보 수집, 제공 경로)

① 환자건강정보는 디지털헬스실의 기획, 감시, 검토, 평가를 통해 허가된 정보시스템, 인터페이스 소프트웨어, 인터페이스 사용자용 주변장치 등의 경로로만 수집 및 제공되어야 한다.

1. 정보시스템(하위시스템 포함) : EMR(electronic medical records system), OCS(Order communication system), PACS(Picture archiving communication system), MUSE, NEIS(National EMR Interface System), CDR/CDW
2. 인터페이스 소프트웨어
3. 인터페이스 사용자용 주변장치 : 디지털 펜, 스캐너, 바코드 리더기, 카드 리더기, 스마트 카드

제12조 (환자건강정보 및 회원정보의 수집, 이용 및 제공)

① 의료원은 '제10조 수집, 이용 및 제공 등에 관한 동의 및 고지"에 근거하여 진료, 청구, 학술연구, 교육, 병원 관리 및 평가 등의 목적으로 환자건강정보를 수집, 이용 및 제공할 수 있다.

② 수집하려는 환자건강정보는 다음과 같다.

1. 성명, 주민등록번호, 주소, 전화번호, 이동전화번호, 이메일 주소
2. 진료 및 진료기록 작성을 위하여 의료진이 필요하다고 판단된 환자건강정보
3. 정보보호위원회 심의에 의해 결정된 기타 환자건강정보

③ 삭제 <2017.01.16>

④ 의료원이 인터넷 홈페이지 등 공개된 매체 또는 장소(이하 "인터넷 홈페이지 등"이라 함)에서 개인정보를 수집하는 경우, 해당 개인정보는 본인의 개인정보를 인터넷 홈페이지 등에 게시하거나 게시하도록 허용한 정보주체의 동의 의사가 명확히 표시되거나 인터넷 홈페이지 등의 표시 내용에 비추어 사회통념상 동의 의사가

있었다고 인정되는 범위 내에서만 이용할 수 있다.

제13조 (수집, 이용 및 제공 등에 관한 동의 및 고지)

① 환자건강정보 및 회원정보를 수집, 이용 및 제공하는 경우 법정대리인 및 정보주체가 지정한 대리인의 동의를 받는다. 단, 진료 목적인 경우에는 제외한다.

② 의료원은 개인정보의 수집과 이용을 위하여 정보주체의 동의를 받고자 하는 경우에는 기본적인 재화 또는 서비스의 제공을 위하여 반드시 필요한 최소한의 개인정보와 부가적인 재화 또는 서비스의 제공을 위하여 필요한 최소한의 개인정보를 구분하여 정보주체에게 알리고 동의를 받아야 한다.

③ 개인정보처리자가 수집, 이용, 제공, 민감정보의 처리 및 고유식별정보 처리에 따라 개인정보를 처리하기 위하여 정보주체의 동의를 얻고자 하는 경우에는 정보주체의 동의가 필요한 경우와 필요하지 않은 경우를 구분하고, 후자의 경우에는 정보주체의 동의 없이 개인정보를 처리할 수 있다는 점과 그 사유를 알려야 한다.

④ 의료원이 민감정보의 처리를 위하여 정보주체에게 동의를 받고자 하는 경우에는 다른 개인정보와 민감정보를 구분하여 민감정보에 대하여는 정보주체가 별도로 동의할 수 있도록 조치를 취하여야 하고 동의를 받을 때에는 다음 각 호의 사항을 정보주체에게 알려야 한다. 다음 각 호의 어느 하나의 사항을 변경하는 경우에도 이를 알리고 동의를 받아야 한다.

1. 민감정보의 수집·이용 목적
2. 수집하려는 민감정보의 항목
3. 민감정보의 보유 및 이용 기간
4. 동의를 거부할 권리가 있다는 사실 및 동의 거부에 따른 불이익이 있는 경우에는 그 불이익의 내용

⑤ 의료원이 고유식별정보의 처리를 위하여 정보주체에게 동의를 받고자 하는 경우에는 다른 개인정보와 고유식별정보를 구분하여 고유식별정보에 대하여는 정보주체가 별도로 동의할 수 있도록 조치를 취하여야 하고 다음 각 호의 사항에 대해 정보주체에게 동의받아야 하며 각 호 어느 하나의 사항을 변경하는 경우에 알리고 동의를 받아야 한다.

1. 고유식별정보의 수집・이용 목적
2. 수집하려는 고유식별정보의 항목

3. 고유식별정보의 보유 및 이용 기간
4. 동의를 거부할 권리가 있다는 사실 및 동의 거부에 따른 불이익이 있는 경우에는 그 불이익의 내용

⑥ 법률에서 예외를 인정하는 경우에는 정보주체 또는 대리인의 동의를 받지 않고, 수집 및 이용이 가능하다.

⑦ 정보주체 또는 대리인이 환자건강정보 수집 및 이용 등에 동의하는 경우 쉽게 이해하고, 알아보기 쉽도록 글씨의 크기를 최소한 9포인트 이상으로 다른 글씨보다 20% 크게 하며, 색깔, 굵기, 밑줄 등을 통하여 강조하여야 한다.

1. 개인정보의 수집·이용 목적 중 재화나 서비스의 홍보 또는 판매권유 등을 위하여 해당 개인정보를 이용하여 정보주체에게 연락할 수 있다는 사실
2. 처리하려는 개인정보의 항목 중 민감정보, 여권번호, 운전면허의 면허번호 및 외국인등록번호
3. 개인정보의 보유 및 이용 기간(제공 시에는 제공받는 자의 보유 및 이용 기간)
4. 개인정보를 제공받는 자 및 개인정보를 제공받는 자의 개인정보 이용 목적

⑧ 정보주체 또는 대리인의 동의가 있어도 다음과 같은 어느 하나에 해당하는 경우에는 환자건강정보 및 회원정보의 전부 또는 일부에 대하여 이용 및 제공을 거부할 수 있다.

1. 정보주체 또는 제3자의 생명, 신체, 재산 및 기타 권리 이익을 해칠 우려가 있는 경우
2. 의료원의 적정한 업무수행에 명백한 지장을 끼칠 우려가 있는 경우
3. 다른 법령에 위반하는 경우

⑨ 의료원은 정보주체 또는 법정 대리인의 동의가 있는 경우 동의한 목적 내에서 환자건강정보 및 회원정보를 이용하거나 제공할 수 있다.

⑩ 의료원은 다음 각호에 해당하는 경우 정보주체 또는 대리인의 동의 없이 환자건강정보를 이용하거나 제공할 수 있다.

1. “국민건강보험법” 제13조, 제43조 및 제56조의 규정에 따른 급여비용 심사, 지급, 사후관리 및 요양급여의 적정성 평가, 가감지급 등을 위하여 국민건강보험공단 또는 건강보험심사평가원에 제공하는 경우
2. “의료급여법” 제11조 제2항의 규정에 따른 급여비용의 심사청구 및 의료급여의 적정성 평가 등을 위하여 급여비용심사기관에 제공하는 경우

3. “전염병예방법” 제4조 내지 제6조 및 제21조의 규정에 따른 전염병 환자 및 예방접종 후 이상반응자 등이 발생하여 이를 보고 또는 신고하여야 하는 경우
4. “혈액관리법” 제8조 제2항 및 제10조 1항의 규정에 따른 부적격 혈액을 발견하거나 특정수혈부작용이 발생하여 이를 보고 또는 신고하여야 하는 경우
5. “후천성면역결핍증예방법” 제5조의 규정에 따른 감염자를 보고 또는 신고하여야 하는 경우
6. “결핵예방법” 제19조 및 제20조의 규정에 따른 결핵예방접종 및 결핵환자 등에 관한 사항을 보고 또는 신고하여야 하는 경우
7. “암관리법” 제8조의 규정에 따른 암등록 통계사업에 필요한 자료를 제출하는 경우
8. “정신보건법” 제39조 규정에 따라 정신보건시설 설치 운영 현황 등의 보고에 필요한 자료를 제공하는 경우
9. “통계법” 제25조의 규정에 따라 지정통계 중 사망원인 통계작성에 필요한 자료를 제공하는 경우
10. “형사소송법” 제106조, 제215조, 제218조에 따라 제공하는 경우
11. “민사소송법” 제344조(문서제출명령), 제352조(문서송부촉탁), 제364조(검증), 제375조(증거보전)등 법원이 환자건강정보 관련 정보의 제출을 명한 경우
12. 기타 다른 법령의 규정에 의한 경우
13. 정보주체가 의사를 표시할 수 없는 상태에 있거나 주소불명 등으로 동의를 할 수 없는 경우로서 환자건강정보를 정보주체 외의 자에게 이용하게 하거나 제공하는 것이 명백히 정보주체에게 이익이 된다고 인정되는 경우

제14조 (개인정보의 목적 외 이용 등)

① 의료원은 개인정보를 목적 외의 용도로 제3자에게 제공하는 경우에는 제공받는 자에게 이용 목적, 이용 방법, 이용 기간, 이용 형태 등을 제한하거나, 개인정보의 안전성 확보를 위하여 필요한 구체적인 조치를 마련하도록 문서(전자문서 포함)로 요청할 수 있다. 이 경우 요청을 받은 자는 그에 따른 조치를 취하고 그 사실을 의료원 개인정보보호실무담당자에게 문서로 알려야 한다.

② 의료원은 개인정보를 목적 외의 용도로 제3자에게 제공하는 경우에는 개인정보를 제공하는 자와 개인정보를 제공받는 자는 개인정보의 안전성에 관한 책임관계를 명확히 하여야 한다.

③ 의료원은 정보주체에게 개인정보를 제공받는 자를 알리는 경우에는 그 성명(법인 또는 단체인 경우에는 그 명칭)과 연락처를 함께 알려야 한다.

④ 삭제 <2017.01.16>

제15조 (개인정보 수집 출처 등 고지)

① 의료원이 정보주체 이외로부터 수집한 개인정보를 처리하는 때에는 정당한 사유가 없는 한 정보주체의 요구가 있으면 다음 각 호의 모든 사항을 정보주체에게 알려야 한다.

1. 개인정보의 수집 출처
2. 개인정보의 처리 목적
3. 개인정보 처리의 정지를 요구하거나 동의를 철회할 권리가 있다는 사실

② 제1항에 따른 정보주체의 요구를 거부하는 경우에는 정당한 사유가 없는 한 그 거부의 근거와 사유를 정보주체에게 알려야 한다.

제16조 삭제 <2017.01.16>

제17조 (개인정보처리방침의 작성)

① 개인정보 처리방침을 수립하거나 변경하는 경우에는 인터넷 홈페이지를 통해 지속적으로 개제하여야 하며 이 경우 "개인정보 처리방침"이라는 명칭을 사용하되, 글자 크기, 색상 등을 활용하여 다른 고지사항과 구분함으로써 정보주체가 쉽게 확인할 수 있도록 하여야 한다.

② 개인정보처리자가 개인정보 처리방침을 변경하는 경우에는 변경 및 시행의 시기, 변경된 내용을 지속적으로 공개하여야 하며, 변경된 내용은 정보주체가 쉽게 확인할 수 있도록 변경 전 후를 비교하여 공개하여야 한다.

제18조 (개인정보처리방침의 작성기준 등)

① 의료원이 개인정보 처리방침을 작성하는 때에는 개인정보처리방침의 내용을 알기 쉬운 용어로 구체적이고 명확하게 표현하여야 한다.

② 의료원은 개인정보의 처리 목적에 필요한 최소한의 개인정보라는 점을 밝혀야 한다.

③ 의료원이 목적에 필요한 최소한의 개인정보 이외에 개인별 맞춤서비스 등을 위하여

처리하는 개인정보의 항목이 있는 경우에는 양자를 구별하여 표시하여야 한다.

④ 의료원이 개인정보처리방침을 작성할 때에는 다음 각 호의 사항을 필수적 기재사항으로 모두 포함하여야 한다.

1. 개인정보의 처리 목적
2. 개인정보의 처리 및 보유 기간
3. 개인정보의 제3자 제공에 관한 사항(해당되는 경우에만 정한다)
4. 개인정보처리의 위탁에 관한 사항(해당되는 경우에만 정한다)
5. 정보주체의 권리·의무 및 그 행사방법에 관한 사항
6. 처리하는 개인정보의 항목
7. 개인정보의 파기에 관한 사항
8. 개인정보 보호책임자에 관한 사항
9. 개인정보 처리방침의 변경에 관한 사항
10. 개인정보의 안전성 확보조치에 관한 사항
11. 정보주체의 권익침해에 대한 구제방법
12. 개인정보의 열람청구를 접수·처리하는 부서
13. 인터넷접속정보파일 등 개인정보를 자동으로 수집하는 장치의 설치 운영 및 그 거부에 관한 사항(해당하는 경우에만 정한다)

제19조 (개인정보처리방침의 변경에 관한 사항)

현 개인정보처리방침은 정부의 정책 또는 보안기술의 변경 등에 따라 수시로 변경될 수 있으며, 내용의 추가, 삭제 및 수정이 있을 경우 개정 최소 10일 전부터 홈페이지 '공지'란 및 기타 정보주체가 쉽게 확인 가능한 장소에 공지를 통해 고지한다.

제20조 삭제 <2017.01.16>

제21조 (환자건강정보 수집 및 이용의 동의 철회)

정보주체 및 대리인은 '동의 철회 신청서'를 통해 환자건강정보의 수집 및 이용 등에 관한 동의를 철회할 수 있다.

① 의료원은 환자건강정보 수집 및 이용의 동의 철회를 요청한 경우라도 동의 철회로 정보주체의 진료 및 치료에 위해가 되는 경우 동의 철회를 거부할 수 있다.

동의 철회 신청서를 접수 받은 담당자는 본인 여부를 확인하고, 필요한 조치를 취한 후 해당 결과를 요청자에게 통지한다.

② 환자건강정보의 제3자 제공에 대한 동의 철회가 있는 경우 담당자는 제공한 취급기관에 해당 환자건강정보를 파기하는 등의 조치를 취하도록 요청하고, 이러한 조치내용을 요청자에게 통지한다.

제22조 (환자건강정보 수집 및 이용의 정정 요청 절차)

정보주체 및 대리인은 "의무기록 정정 신청서[환자용]"를 통해 정보주체 및 대리인이 진술한 환자건강정보에 한하여 정정을 요청할 수 있다.

① 정정 요청을 받은 담당자는 해당 내용을 처리하고, 조치사항을 요청자에게 통지한다.

② 작성자가 정정 요청한 내용에 대하여 오류를 인정할 수 없는 경우 정정요청을 거부할 수 있으며, 그 사유를 요청자에게 설명하여야 한다.

제23조 (환자건강정보의 열람 및 사본발급 절차)

정보주체 및 대리인은 해당 정보주체의 환자건강정보에 대한 열람 또는 사본발급을 신청할 수 있다.

① 열람 및 사본 발급 신청을 받은 담당자는 본인 여부를 확인하고 처리하여야 한다.

② 담당자는 정보주체 및 대리인이 환자건강정보에 대한 열람을 요청하여도 정보주체 및 타인과의 관계 등에 위해를 줄 수 있는 경우 해당 정보에 대한 열람을 거부할 수 있으며, 그 사유를 요청자에게 설명하여야 한다.

③ 담당자는 정보주체의 치료목적상 불가피한 경우 사본발급을 거부할 수 있다.

제24조 (환자건강정보의 생성과 갱신, 소멸)

환자진료와 직·간접으로 관련된 정보의 생성과 갱신, 소멸에 관하여 책임있는 자가 수행하여야 한다. 책임있는 자라 함은 해당 환자에게 직접 진료를 행하거나 진료를 지원하기 위한 활동에 참여하는 자를 말한다.

① 해당 기관 소속의 의료직 종사자로 의사, 간호사, 의료기사, 약사, 의무기록사 등

② 환자건강정보의 활용은 정보보호와 비밀 유지를 전제로 하며, 상세한 자격권한은 '세브란스병원 내규 14.5 의무기록정보 접근권한'에 명시한 지침을 근거로 한다.

제25조 (환자건강정보의 유지 및 관리)

환자건강정보의 생성 및 갱신, 소멸은 환자에게 의료서비스를 제공하는 관련자와 접근이 허가된 제 3자가 식별 가능한 형태로 보관, 유지되어야 하며 다음과 같은 사항이 포함되어야 한다.

① 생성 및 갱신, 소멸은 해당 데이터베이스의 물리적인 변형과 변경, 삭제를 의미하지 않는다.

② 환자와 직·간접적으로 관련된 모든 자료(의무기록, 의료정보 포함)의 보관기간은 관련 법규에 따르며, 보관·저장 방법 및 시기는 디지털헬스실의 운영 내규를 따른다

③ 사용자에게 제공되는 환자건강정보는 최신 상태를 유지할 수 있도록 구성한다.

④ 환자건강정보와 관련된 모든 수행 내역은 별도의 데이터베이스를 통해 보관, 유지, 감시, 평가하며 상세한 내용은 '서버보안지침서' 를 따른다.

제26조 (필수 항목)

생성 및 갱신, 소멸된 환자건강정보에는 다음과 같은 항목이 포함되어야 한다.

① 수행 날짜 및 시간

② 수행자를 식별할 수 있는 코드, 명칭과 인증된 해당 전자서명

③ 모듈 별로 사전 정의된 해당 데이터 세트

④ 의무기록 관리를 위해 별도로 규정한 항목은 'INF.6.1.정보관리-의무기록관리규정' 을 따른다.

제27조 (정보주체 및 법정대리인의 권리 · 의무 및 그 행사방법에 관한 사항)

① 환자(정보주체)는 등록되어 있는 자신의 개인정보를 의무기록 사본발급[열람]신청서, 의무기록 정정 신청서를 통하여 열람하거나 정정을 요구할 수 있다. 그러나 의료법 등 기타 다른 법령에서 요구하는 서류가 구비되어야 하며, 미 제출 시 거절될 수 있다. 또한 정정을 위한 입증책임은 개인정보보호법 제36조에 의거하여, 환자 본인에게 있다.

② 개인정보의 열람, 정정 요구를 하고자 할 경우 직접 또는 대리인을 통하여 서면 신청서와 구비서류 제출로만 가능하며, 요청한 사항에 대해서는 의료원에서 심의 후 관련 법령에 따라 처리하고 그 결과를 통지한다.

③ 의료원은 만14세 미만 아동 및 건강상의 이유로 의사표시를 할 수 없는 자의

법정대리인의 동의를 받기 위하여 법정대리인의 성명과 연락처 등 최소한의 정보를 수집할 수 있으며, 개인정보처리방침에서 규정하고 있는 방법에 따라 법정대리인의 동의를 받아야 한다.

④ 이용자 및 법정대리인은 개인정보와 관련하여 전화, 서면 등을 통하여 의료원에 연락을 하여 권리를 행사할 수 있으며, 의료원은 지체 없이 필요한 조치를 한다. 단, 법에 의해 보관이 의무화된 개인정보는 제외한다.

제28조 (동의철회 및 개인정보 파기에 관한 사항)

① 환자(정보주체)는 진료접수시 개인정보의 수집·이용 및 제공에 대해 동의한 내용을 언제든지 철회할 수 있다. 철회방법은 개인정보관리책임자 또는 관리부서에 서면, 전화 등으로 연락하며, 지체 없이 환자(정보주체)의 개인정보를 파기하는 등 필요한 조치를 한다.

② 의료원은 수집된 환자(정보주체)의 개인정보를 제43조의 "개인정보의 처리 및 보유기간"동안 보유한다. 의료원은 보유기간의 경과, 처리 목적 달성 등 그 개인정보가 불필요하게 되었을 때에는 지체 없이 그 개인정보를 파기한다. 의료원은 정보주체의 개인정보에 오류가 있거나 보존 기간을 경과한 것이 판명되는 등 정정·삭제를 할 필요가 있다고 인정되는 경우에는 지체 없이 정정·삭제 한다.

③ 의료원은 개인정보를 파기할 때에는, 전자적 파일 형태인 경우 복원이 불가능한 방법으로 영구 삭제하고, 기타 서면 등 기록매체인 경우 파쇄 또는 소각한다.

제29조 (서비스 개발)

① 환자건강정보의 생성 및 갱신, 소멸을 위한 새로운 서비스 개발은 정기, 수시로 요청 가능하며 개발 시기 및 자원 할당 계획에 따라 적용된다.

② 환자건강정보의 생성 및 갱신, 소멸을 위한 새로운 서비스 개발은 정기, 수시로 해당 경로를 통해 요청할 수 있다.

③ 디지털헬스실은 정보 요구 수준에 따라 해당 위원회를 소집하고, 필요 시 외부 자원의 활용 계획을 수립한다.

④ 서비스 개발과 관련된 전반적 사항은 해당 사용자가 인식할 수 있도록 절차를 유지한다.

⑤ 정보보호담당자(부서 담당자)는 "보안성 검토결과서"를 작성하여 정보보호 및 보안

실무담당자에게 제출한다. 상세 절차는 보안성 검토 지침서를 따른다.

제30조 (환자건강정보의 접근 권한관리)

의료원은 직종별, 부서별, 직무 및 직급 등에 따라 환자건강정보에 접근할 수 있는 필요한 최소한의 범위 및 권한을 차별화하여 "사용자 보안관리지침서" 에 규정한다.

① 정보보호관리자(소속 부서장)는 개인정보취급자를 업무상 필요한 한도 내에서 최소한으로 두어야 하며, 개인정보취급자의 개인정보 처리범위를 업무상 필요한 한도 내에서 최소한으로 제한하여야 한다.

② 정보보호관리자(소속 부서장)은 개인정보취급자로 하여금 보안서약서를 제출하도록 하는 등 적절한 관리,감독을 해야 하며, 입사, 전보, 퇴직 등으로 인하여 자격이 변경되었을 경우 변경과 동시에 환자건강정보의 접근 권한이 변경되거나 소멸된다.

③ 삭제 <2024.01.08>

④ 의료원은 환자건강정보의 접근 권한을 변경하는 경우에는 그 이유 및 변경 내용 등에 대한 이력관리를 한다.

제31조 (비밀번호 관리)

환자건강정보 접근자는 의료원 정보시스템의 비밀번호와 전사서명의 비밀번호를 타인에게 알려주어서는 안 된다. 단, 업무상 알려 주었을 경우 추후 발생되는 환자건강정보의 유출과 관련된 법적 책임 및 의료원 정책에 따른 책임은 비밀번호 소유자에게 부가된다.

① 환자건강정보 접근자는 추측할 수 있는 비밀번호를 사용하지 않아야 하며, 정책에 따라 주기적으로 변경해야 한다. 이와 관련된 사항은 "사용자 보안관리지침서" 에서 정한 바에 따른다.

제32조 (환자건강정보의 접근 로그 관리)

환자건강정보 접근자가 의료원 정보시스템(u-severance)외의 방법을 통하여 환자건강정보를 접근하는 경우 접근자, 접근일시, 접근내용 등을 기록하고 관리하여야 한다.

① 관련부서는 접근 로그를 주기적으로 확인하고 감독하여야 한다.

② 환자건강정보에 관한 접근 로그는 정기적으로 백업하고, 관련 법률에서 정하는 보관기간 동안 보관하여야 한다.

제33조 (환자건강정보의 출력 조치)

의료원은 환자건강정보보호를 위하여 업무 및 출력의 용도에 따라 출력자를 제한하여야 한다.

① 업무 및 출력의 용도에 따른 출력자 외에는 환자건강정보를 출력할 수 없으며, 정당한 사유로 인하여 출력이 필요한 경우에는 정보보호관리자(소속 부서장)의 사전 승인을 받아야 한다.

② 환자건강정보 유출 시 책임소재를 명확히 하기 위하여 환자건강정보의 출력물에 출력자, 출력일시 등을 표기하여야 한다.

③ 환자건강정보의 출력자, 출력일시, 출력내용 등을 로그로 남기고 정보보호관리자(해당 부서장)이 주기적으로 확인하여야 한다.

제34조 (개인정보처리의 위탁에 관한 사항)

① 의료원은 개인정보 처리 등 특정 업무를 위탁할 경우 관계 법령에 따라 위탁계약 시 개인정보가 안전하게 관리될 수 있도록 필요한 사항을 공개한다.

② 위탁기관의 개인정보 보유 및 이용기간은 위탁이 종료되고 관련 법령에 의한 보존기간이 종료될 때까지 이며, 위탁하는 업무의 내용과 수탁자의 성명을 별도 관리한다.

제35조 (개인정보 처리 위탁관리의 보호 조치)

① 위수탁업체가 의료원 정보시스템을 통하여 환자건강정보에 접근할 때 접근, 열람 및 처리 등에 대한 로그를 남기도록 하여야 한다.

② 위수탁업체가 소속 직원들에 대하여 정보보호 교육을 실시하고, 환자건강정보 취급에 있어 계약 내용을 충실히 이행하고 있는지 주기적으로 점검하여야 한다.

제36조 (외부 연구자의 보호 조치)

① 외부 연구자가 정보시스템을 통하여 환자의 건강정보에 접근할 때 공인인증서, VPN 사용 등의 안전조치를 수행하여 내부네트워크로 접속해야 하며 접근 및 열람에 대한 로그를 남기도록 한다.

② 외부 연구자들에 대하여 정보보호 교육을 실시하고, 환자건강정보 취급에 있어 계약 내용을 충실히 이행하고 있는지 주기적으로 점검하여야 한다.

제37조 (자원봉사자와 호스피스의 보호 조치)

① 자원봉사 신청과 호스피스 교육을 마친 봉사자에 대하여 개인정보가 포함된 업무를 할 경우 개인정보에 접근하기 위해서는 '정보보호서약서'에 서명하여야 한다.

② 자원봉사 신청서와 호스피스 교육신청서에는 개인정보가 최소화 되도록 하며 이용 목적 달성 이후에는 각 부서 지침에 따라 파기 하고 파기 기록을 남긴다.

③ 봉사자들에 대하여 정보보호 교육을 실시하고, 환자건강정보 취급에 있어 서약 내용을 충실히 이행하고 있는지 주기적으로 점검하여야 한다.

제38조 (서약서 관리)

의료원은 교직원 및 외부자(외주용역, 외부출입자 및 기타 의료원의 정보시스템, 네트워크에 접근이 가능한 자 등)에게 정보보호서약서를 받아야 한다.

① 정보보호서약서는 다음 각 호의 사항이 포함되어야 한다.

1. 비밀유지 서약
2. 정보제공금지
3. 환자건강정보 취급제한
4. 개인정보 통제·활용 동의 방안

제39조 (환자건강정보 비밀 누설금지)

의료원 교직원 및 외부자(외주용역, 외부출입자 및 기타 의료원의 정보시스템, 네트워크에 접근이 가능한 자 등)는 근무 중에 알게 된 환자건강정보와 업무비밀을 누설하여서는 안 된다.

제40조 (개인정보 유출 통지시기 및 항목)

① 의료원은 실제로 유출 사고가 발생한 것으로 확인된 때에는 해당 정보주체에게 다음 각 호의 사항을 알려야 한다.

1. 유출된 개인정보의 항목
2. 유출된 시점과 그 경위
3. 유출로 인하여 발생할 수 있는 피해를 최소화하기 위하여 정보주체가 할 수 있는 방법 등에 관한 정보

4. 개인정보처리자의 대응조치 및 피해구제절차
5. 정보주체에게 피해가 발생한 경우 신고 등을 접수할 수 있는 담당부서 및 연락처

② 의료원은 제1항 제2호의 경우 개인정보 유출 사고가 최초 발생한 시점과 알게 된 시점 사이에 시간적 차이가 있는 경우에는 이에 대한 과실유무를 입증하여야 한다.

③ 의료원은 제1항 각 호의 조치를 취한 이후에는 정보주체에게 다음 각 호의 사실만을 일차적으로 알리고, 추후 확인되는 즉시 알릴 수 있다.

1. 정보주체에게 유출이 발생한 사실
2. 제1항의 통지항목 중 확인된 사항

④ 개인정보 유출사고 대응에 관하여는 '침해사고대응 지침서'를 따른다.

제41조 (개인정보 유출 통지방법)

① 의료원은 정보주체에게 통지할 때에는 서면, 전자우편, 모사전송, 전화, 휴대전화 문자전송 또는 이와 유사한 방법을 통하여 지체 없이 정보주체에게 알려야 한다.

② 제1항과 동시에 의료원은 홈페이지 등을 통하여 통지 항목을 공개할 수 있다.

제42조 (개인정보 유출 신고)

① 의료원은 1천명 이상의 정보주체에 관한 개인정보가 유출된 경우에는 정보주체에 대한 통지 및 조치결과를 한국인터넷진흥원에 신고하여야 한다.

② 제1항에 따른 신고는 "[별지 제1호 서식] 개인정보 유출신고서"를 통하여 하여야 한다.

③ 의료원은 전자우편, 팩스 또는 인터넷 사이트를 통하여 유출신고를 할 시간적 여유가 없거나 그밖에 특별한 사정이 있는 때에는 먼저 전화를 통하여 신고한 후, [별지 제1호 시식] 개인정보 유출신고서를 제출할 수 있다.

④ 의료원은 1천명 이상의 정보주체에 관한 개인정보가 유출된 경우에는 통지와 함께 인터넷 홈페이지에 정보주체가 알아보기 쉽도록 통지항목 사항을 7일 이상 게재하여야 한다.

제43조 (개인정보의 처리 및 보유기간에 관한 사항)

의료원은 수집된 개인정보를 아래의 각 호에 명시한 바와 같이 처리 및 보유한다.

① 의료원은 진료의 연속성이나 연구 등을 위하여 위 개인정보의 처리 목적이 달성되고 관련 법령에 의한 보존기간이 종료될 때까지 환자(정보주체)의 개인정보를 처리 및

보유한다.

② 진료 서비스의 제공을 위하여 수집한 경우 : 「의료법 시행규칙 제15조 진료에 관한 기록의 보존」에 명시된 진료기록 보관 기준에 준하여 보관한다.

제44조 (개인정보의 파기방법 및 절차)

① 의료원은 개인정보의 보유기간이 경과된 경우, 개인정보의 처리 목적 달성, 해당 서비스의 폐지, 사업의 종료 등 그 개인정보가 불필요하게 되었을 때에는 정당한 사유가 없는 한 지체없이 그 개인정보를 파기하여야 한다.

② 개인정보 파기 시 개인정보 파일 형태에 따라 다음과 같이 구분하여 파기한다.

1. 전자적 파일 형태인 경우 : 복원이 불가능한 방법으로 영구 삭제
2. 전자적 파일 외의 기록물, 인쇄물, 서면, 그 밖의 기록매체인 경우 : 파쇄 또는 소각

③ 의료원은 개인정보의 파기에 관한 사항을 기록. 관리하여야 한다.

④ 개인정보파기의 시행 및 확인은 개인정보보호책임자의 책임하에 수행된다.

⑤ 개인정보보호책임자는 개인정보 파기 시행 후 파기 결과를 확인하여야 한다.

⑥ 의료원이 개인정보를 파기하지 아니하고 보존하여야 하는 경우에는 법령에 따라 해당 개인정보 또는 개인정보파일을 보존한다는 점을 분명히 표시하여야 한다.

1. 「의료법」 시행규칙 제15조
   - i. 환자 명부 : 5년
   - ii. 진료기록부 : 10년
   - iii. 처방전 : 2년
   - iv. 수술기록 : 10년
   - v. 검사소견기록 : 5년
   - vi. 방사선사진 및 그 소견서 : 5년
   - vii. 간호기록부 : 5년
   - viii. 조산기록부: 5년
   - ix.진단서 등의 부본 (진단서·사망진단서 및 시체검안서 등을 따로 구분하여 보존할 것) : 3년

⑦ 의료원은 법령에 따라 개인정보를 파기하지 않고 보존하는 경우에는 해당 개인정보 또는 개인정보파일을 다른 개인정보와 분리하여 저장·관리한다.

제45조 (개인정보의 안전성 확보조치에 관한 사항)

의료원은 개인정보가 분실, 도난, 누출, 변조 또는 훼손되지 않도록 안전성 확보를 위하여 다음과 같은 기술적 · 관리적 대책을 강구한다.

개인정보 처리와 관련된 접속기록 로그의 보관 주기, 로그 항목, 점검 주기, 다운로드 시 사유확인 등은 개인정보보호위원회 "개인정보의 안전성 확보조치 기준"에 따른다.

① 기술적·물리적

1. 개인정보는 비밀번호에 의해 보호되며, 개인정보 파일을 안전하게 저장 및 전송할 수 있도록 데이터를 암호화하거나 파일 잠금기능(Lock)을 사용하여 중요한 데이터는 별도의 보안기능을 통해 보호한다.
2. 백신 프로그램 등 보안프로그램을 설치하여 컴퓨터 바이러스에 의한 피해를 방지하기 위한 조치를 취하고 백신프로그램은 자동으로 업데이트되며 갑작스런 바이러스가 출현할 경우 백신이 나오는 즉시 이를 제공함으로써 개인정보가 침해되는 것을 방지한다.
3. 해킹 등에 의해 개인정보가 유출되는 것을 방지하기 위하여, 외부로부터 접근이 통제된 구역에 시스템을 설치하고, 침입을 차단하는 장치를 이용하고 있으며, 아울러 침입탐지시스템을 설치하여 24시간 침입을 감시한다.
4. 개인정보취급자가 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하려는 경우에는 가상사설망(VPN) 또는 전용선 등 안전한 접속수단을 적용한다.

② 관리적 대책

1. 의료원은 개인정보의 안전한 처리를 위한 개인정보보호 관리지침서 및 개인정보에 대한 관리와 접근에 필요한 절차를 마련하여 교직원이 이를 숙지하고 준수하도록 하고 준수 여부를 주기적으로 점검한다.
2. 의료원은 개인정보를 취급할 수 있는 자를 최소한으로 제한하고 접근 권한을 관리하며, 교육을 통하여 법규 및 정책을 준수할 수 있도록 한다. 개인정보를 취급하는 자는 다음과 같다.

i. 정보주체를 직 · 간접적으로 상대하여 업무를 처리하는 자

ii. 개인정보관리책임자 및 개인정보관리담당자 등 개인정보 관리 및 개인정보보호 업무를 담당하는 자

iii. 기타 업무상 개인정보의 접근이 불가피한 자

3. 의료원은 개인정보 침해사고 발생에 대응하기 위한 접속기록의 보관 및 위조 · 변조 방지를 위한 조치를 한다.

4. 신규직원 채용 시 정보보호서약서에 서명함으로 직원에 의한 정보(개인정보 포함)유출을 사전에 방지하고, 수시로 개인정보보호 의무를 상기시키며 준수여부를 감사하기 위한 내부절차를 마련하여 시행한다.

5. 개인정보의 위탁 관리

의료원에서 관리하는 개인정보의 처리를 다른 공공기관 또는 다른 전문기관에 위탁하는 경우, 그 업무에 종사하거나 종사하였던 자에 대해 직무상 알게 된 개인정보를 누설 또는 권한 없이 처리하거나 타인의 이용에 제공하는 등 부당한 목적을 위하여 사용하지 않도록 위탁부서에서 아래에 대한 사항에 관하여 필요한 제한이나 절차를 서면으로 정하고 수탁기관으로 하여금 준수하도록 하고 있으며, 실태점검도 실시한다.

i. 위탁업무 수행 목적 외 개인정보의 처리 금지에 관한 사항

ii.개인정보의 기술적·관리적 보호조치에 관한 사항

iii.위탁업무의 목적 및 범위

iv. 재위탁 제한에 관한 사항

v. 개인정보에 대한 접근 제한 등 안전성 확보 조치에 관한 사항

vi.위탁업무와 관련하여 보유하고 있는 개인정보의 관리 현황 점검 등 감독에 관한 사항

vii.수탁자가 준수하여야 할 의무를 위반한 경우의 손해배상 등 책임에 관한 사항

③ 개인정보의 안전성 확보조치에 관한 상세 절차는 다음과 같은 지침을 따른다.

1. 개인정보처리시스템의 접근 권한 관리에 관한 사항은 ‘사용자보안관리지침서’ 등을 따른다.

2. 개인정보처리시스템의 접근 통제에 관한 사항은 ‘네트워크보안지침서’, ‘정보보호시스템보안지침서’ 등을 따른다.

3. 개인정보의 암호화 조치에 관하여는 ‘DB보안지침서’ 등을 따른다.

4. 개인정보취급자의 접속기록 보관 및 점검에 관하여는 '개발 및 응용시스템 보안지침서' 등을 따른다.
5. 악성프로그램 등 방지에 관하여는 '사용자보안관리지침서' 등을 따른다.
6. 개인정보 처리구역 등의 물리적 안전조치에 관하여는 '물리적보안지침서' 등을 따른다.
7. 개인정보 보호조직 구성 및 운영에 관하여는 '정보보호조직관리지침서' 등을 따른다.
8. 개인정보처리시스템의 재해 및 재난 대응에 관하여는 '업무연속성지침서' 등을 따른다.

제46조 (개인정보 보호 교육)

① 개인정보보호책임자는 의료원에서 근무하는 모든 직원(수탁사 포함)들에게 교육을 실시한다.

1. 개인정보 취급자
2. 부서별 개인정보 관리자 및 개인정보 처리자
3. 위수탁업체 소속직원 및 외부 연구자
4. 협진병원 의사 및 간호사
5. 자원봉사자 및 호스피스

② 개인정보보호 교육은 온라인 또는 오프라인을 통해 정기적으로 실시한다.

③ 보안수준이 미흡한 부서 또는 보안 교육을 실시해야 할 필요가 있다고 판단될 경우 필요 시 개인정보보호 및 보안 교육을 실시한다.

제47조 (개인정보의 식별)

① 개인정보 보호책임자는 개인정보를 식별하고 개인정보목록을 작성한다.

② 개인정보 보호책임자는 1항에 따라 중요도를 분리하고 중요도에 따라 관리한다.

③ 삭제 <2017.01.16>

제48조 삭제 <2017.01.16>

제49조 삭제 <2017.01.16>

제50조 (위험도 분석 및 대응방안 마련)

① 개인정보 보호책임자는 내부망에서 주민등록번호를 제외한 고유식별정보를 암호화하지 않고 저장하는 경우 '개인정보 위험도 분석 기준'(행정자치부 매뉴얼)에 따라 위험도 분석을 실시하고 그 결과를 관리하여야 한다.

② 개인정보 보호책임자는 위험도 분석 결과를 활용하여 추가적인 개인정보처리시스템 보호조치를 적용하거나, 고유식별정보를 암호화하는 등 대책을 마련하여야 한다.

제3장 영상정보처리기기 처리 기준

제51조 (영상정보처리기기 설치 운영)

① 영상정보처리기기운영자는 개인영상정보의 처리에 관한 업무를 총괄해서 책임질 개인영상정보 보호책임자를 지정하여야 한다.

② 영상정보처리기기 운영자는 정보주체가 영상정보처리기기가 설치/운영 중임을 쉽게 알아볼 수 있도록 다음 각 호의 사항을 기재한 안내판 설치 등 필요한 조치를 하여야 한다.

1. 설치목적 및 장소
2. 촬영범위 및 시간
3. 관리책임자의 성명 또는 직책 및 연락처
4. 영상정보처리기기 설치/운영에 관한 사무를 위탁하는 경우, 수탁자의 명칭 및 연락처

제52조 (개인영상정보 이용. 제3자 제공 등 제한 등)

① 영상정보처리기기운영자는 다음 각 호의 경우를 제외하고는 개인영상정보를 수집 목적 이외로 이용하거나 제3자에게 제공하여서는 아니 된다.

1. 정보주체에게 동의를 얻은 경우
2. 다른 법률에 특별한 규정이 있는 경우
3. 정보주체 또는 그 법정대리인이 의사표시를 할 수 없는 상태에 있거나 주소불명 등으로 사전 동의를 받을 수 없는 경우로서 명백히 정보주체 또는 제3자의 급박한 생명, 신체, 재산의 이익을 위하여 필요하다고 인정되는 경우

4. 통계작성 및 학술연구 등의 목적을 위하여 필요한 경우로서 특정 개인을 알아볼 수 없는 형태로 개인영상정보를 제공하는 경우

제53조 (보관 및 파기)

① 영상정보처리기기 운영자는 수집한 개인영상정보를 보관 기간이 만료한 때에는 지체없이 파기하여야 한다. 다만, 다른 법령에 특별한 규정이 있는 경우에는 그러하지 아니하다.

② 개인영상정보의 파기 방법은 다음 각 호의 어느 하나와 같다.

1. 개인영상정보가 기록된 출력물(사진 등) 등은 파쇄 또는 소각
2. 전자기적(電磁氣的) 파일 형태의 개인영상정보는 복원이 불가능한 기술적 방법으로 영구 삭제

제54조 (이용. 제3자 제공. 파기의 기록 및 관리)

① 영상정보처리기기 운영자는 개인영상정보를 수집 목적 이외로 이용하거나 제3자에게 제공하는 경우에는 다음 각 호의 사항을 기록하고 이를 관리하여야 한다.

1. 개인영상정보 파일의 명칭
2. 이용하거나 제공받은 자(공공기관 또는 개인)의 명칭
3. 이용 또는 제공의 목적
4. 법령상 이용 또는 제공근거가 있는 경우 그 근거
5. 이용 또는 제공의 기간이 정하여져 있는 경우에는 그 기간
6. 이용 또는 제공의 형태

② 영상정보처리기기 운영자가 개인영상정보를 파기하는 경우에는 다음 사항을 기록하고 관리하여야 한다.

1. 파기하는 개인영상정보 파일의 명칭
2. 개인영상정보 파기일시(사전에 파기 시기 등을 정한 자동 삭제의 경우에는 파기 주기 및 자동 삭제 여부에 대한 확인 시기)
3. 개인영상정보 파기 담당자

③ 삭제 <2024.01.08>

제55조 (영상정보처리기기 설치 및 관리 등의 위탁)

① 영상정보처리기기운영자가 영상정보처리기기의 설치. 운영에 관한 사무를 제3자에게

위탁하는 경우에는 그 내용을 정보주체가 언제든지 쉽게 확인할 수 있도록 안내판에 수탁자의 명칭 등을 공개하여야 한다.

② 영상정보처리기기운영자가 영상정보처리기기의 설치.운영에 관한 사무를 제3자에게 위탁할 경우에는 그 사무를 위탁받은 자가 개인영상정보를 안전하게 처리하고 있는지를 관리.감독하여야 한다.

제56조 (정보주체의 열람 등 요구)

① 정보주체는 영상정보처리기기 운영자가 처리하는 개인영상정보에 대하여 열람 또는 존재확인(이하 "열람 등"이라 한다)을 해당 영상정보처리기기 운영자에게 요구할 수 있다. 이 경우 정보주체가 열람 등을 요구할 수 있는 개인영상정보는 정보주체 자신이 촬영된 개인영상정보 및 명백히 정보주체의 급박한 생명, 신체, 재산의 이익을 위하여 필요한 개인영상정보에 한한다.

② 영상정보처리기기운영자는 제1항에 따른 요구를 받았을 때에는 지체없이 필요한 조치를 취하여야 한다. 이때에 영상정보처리기기운영자는 열람 등 요구를 한 자가 본인이거나 정당한 대리인인지를 주민등록증.운전면허증.여권 등의 신분증명서를 제출받아 확인하여야 한다.

③ 개인영상정보의 보관기간이 경과하여 파기한 경우, 기타 정보주체의 열람 등 요구를 거부할 만한 정당한 사유가 존재하는 경우 영상정보처리기기운영자는 정보주체의 개인영상정보 열람 등 요구를 거부할 수 있다.

④ 열람등 조치를 취하는 경우, 만일 정보주체 이외의 자를 명백히 알아볼 수 있거나 정보주체 이외의 자의 사생활 침해의 우려가 있는 경우에는 해당되는 정보주체 이외의 자의 개인영상정보를 알아볼 수 없도록 보호조치를 취하여야 한다.

제57조 (정보주체의 권익침해에 대한 구제방법)

의료원의 개인정보보호책임자 또는 관리부서에 대한, 신고, 상담 외에, 개인정보침해에 대한 사항을 아래 기관에 문의할 수 있다.

① 한국인터넷진흥원(개인정보침해신고센터)

1. 홈페이지 : privacy.kisa.or.kr
2. 전화번호 : (국번없이)118

② 경찰청 사이버 안전국

1. 홈페이지 : http://ecrm.police.go.kr
2. 전화번호 : (국번없이) 182

③ 대검찰청 사이버 수사과

1. 홈페이지 : http://www.spo.go.kr
2. 전화번호 : (국번없이) 1301

④ 개인정보 분쟁조정위원회(개인정보보호위원회 운영)

1. 홈페이지 : http://www.kopico.go.kr
2. 전화번호 : 1833-6972

제58조 (개인영상정보의 안전성 확보를 위한 조치)

① 영상정보처리기기 운영자는 개인영상정보가 분실. 도난. 유출. 변조 또는 훼손되지 아니하도록 안전성 확보를 위하여 다음 각 호의 조치를 하여야 한다.

1. 개인영상정보의 안전한 처리를 위한 내부 관리계획의 수립/시행
2. 개인영상정보에 대한 접근 통제 및 접근 권한의 제한 조치
3. 개인영상정보를 안전하게 저장/전송할 수 있는 기술의 적용 (네트워크 카메라의 경우 안전한 전송을 위한 암호화 조치, 개인영상정보파일 저장 시 비밀번호 설정 등)
4. 처리기록의 보관 및 위조/변조 방지를 위한 조치 (개인영상정보의 생성 일시 및 열람할 경우에 열람 목적/열람자/열람 일시 등 기록/관리 조치 등)
5. 개인영상정보의 안전한 물리적 보관을 위한 보관시설 마련 또는 잠금장치 설치

② 영상정보처리기기 운영자는 영상정보처리기기 설치운영으로 인하여 정보주체의 개인영상정보의 침해가 우려되는 경우에는 자체점검 등 개인영상정보의 침해 방지를 위해 적극 노력하여야 한다.

제59조 (기타 개인정보보호 정책)

① 의료원의 환자건강정보를 제외한 기타 개인정보보호 정책은 다음의 문서를 준용하여 적용한다.

1. 개인정보보호법
2. 표준 개인정보보호지침: 제정 2020.8.11, 개인정보보호위원회 고시 제2020-1호
3. 개인정보의 안전성 확보조치 기준

4. 연세의료원 개인정보처리방침

② 개인정보보호 책임자는 인가되지 않은 개인정보처리 활동을 탐지하기 위해 모니터링 절차 수립한다.

③ 개인정보보호 책임자는 법률, 규정 변경 및 외부 위험 요인 변화에 따라 정책을 개선하며, 정책 변경 시 관련 내용을 검토해 반영한다.

제60조 (시행과 갱신)

상기 지침서의 시행과 갱신을 위한 상세한 세부사항은 정보보호규정 '제4장 정보보호 정책'에 준한다.

[별지 제1호 서식] 개인정보 유출 신고서

개인정보 유출신고서

<table>
<tr><td>기관명</td><td colspan="5"></td></tr>
<tr><td>정보주체에의 통지 여부</td><td colspan="5"></td></tr>
<tr><td>유출된 개인정보의 항목 및 규모</td><td colspan="5"></td></tr>
<tr><td>유출된 시점과 그 경위</td><td colspan="5"></td></tr>
<tr><td>유출피해 최소화 대책·조치 및 결과</td><td colspan="5"></td></tr>
<tr><td>정보주체가 할 수 있는 피해 최소화 방법 및 구제절차</td><td colspan="5"></td></tr>
<tr><td rowspan="3">담당부서·담당자 및 연락처</td><td></td><td>성명</td><td>부서</td><td>직위</td><td>연락처</td></tr>
<tr><td>개인정보 보호책임자</td><td></td><td></td><td></td><td></td></tr>
<tr><td>개인정보 취급자</td><td></td><td></td><td></td><td></td></tr>
</table>

유출신고접수기관	기관명	담당자명	연락처

[별지 제2호 서식] 삭제 <2024.01.08>

[별지 제3호 서식] 삭제 <2024.01.08>

[별지 제4호 서식] 삭제 <2024.01.08>